Whitepaper Técnico: Evaluación de Riesgos y Robustez Física en Infraestructuras RTLS basadas en el Estándar IEEE 802.15.4z

Realizado por Ignacio Arduengo Cuesta (Nacho)

Tabla de contenidos

Resumen ejecutivo 3

Fundamentos técnicos 3

La clase de vulnerabilidad: interferencia reactiva al preámbulo 5

Modelado de riesgo posicional y de disponibilidad 6

Fundamento de validez y metodología de evaluación 7

Estrategias de mitigación y robustez 8

Conclusiones 10

Referencias 10

El campo STS de IEEE 802.15.4z protege la integridad del timestamp de rango, pero no la fase de adquisición del preámbulo: por eso una interferencia reactiva dirigida al campo SYNC puede degradar la disponibilidad de un sistema RTLS sin quebrar la criptografía, y la defensa debe residir en mecanismos adaptativos de la propia capa física (PHY).

Resumen ejecutivo

La tecnología de banda ultraancha (UWB) se ha consolidado como el estándar de referencia para el posicionamiento de alta precisión en tiempo real (RTLS), con exactitudes a nivel centimétrico que la hacen idónea para entornos de misión crítica: control de acceso vehicular sin llave, pagos de proximidad y arbitraje deportivo automatizado. En estos entornos, la disponibilidad y la integridad del canal radio no son una comodidad, sino un requisito operativo.

La enmienda IEEE 802.15.4z introdujo el campo STS (Scrambled Timestamp Sequence), una secuencia cifrada que protege la integridad del instante de llegada (ToA) frente a ataques de manipulación de distancia. El hallazgo central de este documento es una distinción de diseño a menudo pasada por alto: el STS asegura la medida, pero no la adquisición. La correlación del STS solo opera después de que el receptor haya sincronizado con el preámbulo público (campo SYNC); dicho de otro modo, la sincronización es previa e independiente de la validación criptográfica. Un adversario que no posee la clave y que, por tanto, no puede falsificar el STS, conserva no obstante la capacidad de impedir que la trama llegue siquiera a la fase en la que el STS actuaría.

Esto abre un vector de denegación de servicio (DoS) por interferencia reactiva sobre el preámbulo, documentado en la literatura académica reciente sobre 802.15.4z. La consecuencia para la evaluación de riesgos es clara: en un RTLS de alta disponibilidad, la robustez no puede delegarse únicamente en las primitivas criptográficas de capa superior. Debe complementarse con defensas adaptativas en la propia capa física (PHY). Este whitepaper modela el fallo a nivel de principio, caracteriza el riesgo en términos de propiedades del sistema y desarrolla tres contramedidas concurrentes —aleatorización temporal del preámbulo, discriminación por firma del perfil de canal (CIR) y localización inversa de emisores estáticos por TDOA— orientadas a preservar la disponibilidad sin comprometer la precisión.

Fundamentos técnicos

A diferencia de las tecnologías basadas en intensidad de señal (RSSI), como Wi-Fi o BLE, UWB transmite pulsos electromagnéticos de duración del orden de nanosegundos sobre anchos de banda de al menos 499,2 MHz. Esta resolución temporal permite estimar el tiempo de vuelo (ToF) con precisión de nanosegundos y, de ahí, posiciones con error centimétrico incluso bajo propagación multitrayecto. El modo de interés para RTLS de alta tasa es el HRP (High Rate Pulse repetition frequency) definido en 802.15.4z.

Arquitectura RTLS de referencia. Un sistema de circuito cerrado se compone de un conjunto de anclas fijas (receptores) en coordenadas tridimensionales conocidas, sincronizadas entre sí a nivel de picosegundos por un reloj maestro, y de uno o varios nodos móviles (tags) que emiten tramas UWB de forma periódica. El posicionamiento puede resolverse por rango bidireccional (DS-TWR), que mide directamente el ToF mediante intercambio de tramas, o por diferencia de tiempos de llegada (TDOA), en el que el servidor central resuelve la posición del tag a partir de las diferencias de instante de recepción entre pares de anclas. Para dos anclas i y j en posiciones conocidas, la diferencia de distancias define una hipérbola:

$$\|p - a_i\| - \|p - a_j\| = c \cdot (t_i - t_j)$$

La intersección de las hipérbolas de varios pares de anclas determina la posición tridimensional del tag. El sistema opera dentro del límite regulatorio de densidad espectral de potencia para dispositivos UWB de corto alcance, fijado en −41,3 dBm/MHz por el CNAF en España (armonizado con ETSI y FCC).

El papel del STS frente al preámbulo. Una trama HRP se estructura en campos sucesivos, cada uno con una función distinta. La tabla resume dónde reside la protección criptográfica y, críticamente, dónde no:

Campo	**Función**	**Estado**	**Papel en seguridad**
SYNC (preámbulo)	Detección de presencia y sincronización del receptor (adquisición)	Público, no cifrado	Ninguno — superficie expuesta
SFD	Delimitador de inicio de trama; fija el RMARKER de referencia temporal	Público	Ninguno directo
PHR + carga	Cabecera y datos de la trama	Según configuración MAC	Integridad de datos, no de rango
STS	Secuencia cifrada para estimación segura del ToA	Cifrado (AES-128)	Integridad del timestamp de rango

El STS previene de forma efectiva la manipulación de la medida de distancia —un atacante sin la clave no puede predecir ni clonar la secuencia—, pero, como se detalla en la sección siguiente, su correlación solo es útil una vez que la sincronización con el preámbulo ya ha tenido éxito.

La clase de vulnerabilidad: interferencia reactiva al preámbulo

La adquisición precede a la validación. El receptor UWB adquiere la trama correlando la señal entrante contra el código de preámbulo conocido. El estándar emplea dos umbrales: uno bajo para detectar la presencia de un pulso UWB y otro, más exigente, para la sincronización legítima, que fija el instante de referencia (RMARKER) usado después por el resto de la trama. El punto crítico, señalado explícitamente en la literatura, es que el STS no puede sustituir al preámbulo: su correlación solo funciona una vez lograda una buena sincronización (Yang et al., 2024). Por tanto, si la adquisición sobre el campo SYNC —público y no cifrado— falla, la trama se descarta antes de que el STS llegue a evaluarse. La protección criptográfica queda estructuralmente fuera de juego, no por haber sido rota, sino por no haber sido alcanzada.

Mecanismo físico. La sincronización depende de que el pico de correlación cruzada normalizada (NCC) entre la señal recibida y la réplica local del preámbulo supere el umbral de sincronización:

$$\rho(\tau) = |\Sigma_t\, r(t) \cdot p^*(t-\tau)| \,/\, \sqrt{(\,\Sigma_t\, |r(t)|^2 \cdot \Sigma_t\, |p(t)|^2\,)}$$

Una inyección de energía en banda, temporalmente solapada con la ventana del SYNC, eleva el término de normalización y añade componentes no correlados que deprimen el pico normalizado. Cuando ρ cae por debajo del umbral, el receptor no logra el enganche del reloj: no hay RMARKER válido, y la trama completa se pierde. A diferencia del jamming de barrido continuo —que satura el canal pero eleva de forma sostenida el piso de ruido y dispara las alarmas de los monitores de espectro—, una interferencia reactiva que solo emite durante el preámbulo mantiene el ruido promediado en el tiempo prácticamente inalterado. Esta discreción es precisamente lo que la hace difícil de detectar con contramedidas basadas en umbral de energía, y explica por qué la investigación la describe como un ataque de bajo perfil energético.

Contexto en la literatura. Este vector pertenece a una familia más amplia de ataques de capa física sobre UWB seguro. El trabajo sobre reducción de distancia en HRP UWB (Leu et al., USENIX Security 2022) y sobre imperfecciones de reloj (Anliker et al., USENIX Security 2023) demostró que las garantías del STS son más estrechas de lo que sugiere su descripción; UWBAD (Yang et al., 2024) trasladó el foco desde la manipulación de la medida hacia la denegación de servicio, mostrando que el proceso de correlación normalizada es explotable con chips comerciales. El consenso que emerge de estos trabajos es coherente: la seguridad de 802.15.4z se concentra en la integridad de la medida y deja la disponibilidad de la adquisición como responsabilidad del diseño del radio, no del estándar.

Modelado de riesgo posicional y de disponibilidad

El riesgo de un RTLS frente a la interferencia reactiva no es uniforme: depende de propiedades geométricas y algorítmicas del propio sistema. Modelarlo en estos términos —y no como un catálogo de técnicas ofensivas— permite al responsable de seguridad razonar sobre dónde es frágil la arquitectura y qué controles la endurecen. La tabla recoge los cuatro factores estructurales más relevantes.

Factor del sistema	**Por qué eleva el riesgo**	**Implicación defensiva**
Dependencia de línea de visión directa (LoS)	La adquisición es más fiable en LoS; una fuente hostil con LoS hacia las anclas maximiza su efecto sobre la correlación	El control del perímetro con visión directa al área cubierta es un control de seguridad física, no solo estético
Coplanaridad con la señal legítima	Si la interferencia comparte plano y vectores de aproximación con el tag, el filtrado por ángulo de llegada (AoA) pierde poder discriminativo	No puede confiarse la defensa a la discriminación espacial por sí sola; hace falta discriminación temporal y por firma de canal
Sensibilidad combinatoria del TDOA	Múltiples arribos concurrentes con timestamps inconsistentes inflan el problema de asociación hiperbólica en el servidor	El solver central debe acotar y descartar asociaciones espurias antes de que saturen los hilos de cálculo
Escalado de potencia con la proximidad	La potencia de interferencia recibida crece al acercarse la fuente, por lo que una fuente próxima necesita muy poca potencia emitida	La gestión del riesgo debe asumir fuentes de baja potencia dentro del perímetro cercano, invisibles a los inhibidores clásicos

Discriminación espacial y su límite. Los receptores avanzados pueden estimar el ángulo de llegada y rechazar señales fuera del volumen esperado. Esta defensa es efectiva contra fuentes claramente externas, pero su poder discriminativo se degrada cuando la fuente hostil ocupa aproximadamente el mismo plano tridimensional que la señal de interés: dos frentes de onda que llegan con ángulos casi idénticos no son separables por AoA. La conclusión defensiva no es que el AoA sea inútil, sino que no puede ser la única capa de discriminación.

Carga combinatoria del posicionamiento. El cálculo TDOA empareja instantes de llegada entre pares de anclas para resolver hipérbolas. Ante múltiples fuentes estáticas que inyectan pulsos concurrentes, el número de asociaciones candidatas crece y una

fracción de ellas produce soluciones inconsistentes (“posiciones fantasma”). Si el servidor no acota explícitamente el espacio de asociación, el coste de cálculo por época puede dispararse y degradar la tasa de actualización en tiempo real. Esta fragilidad es, a la vez, una oportunidad defensiva: la propia rigidez espacial de las fuentes estáticas ofrece una firma que el servidor puede aprovechar, como se desarrolla en las mitigaciones.

Nota sobre el alcance del modelo. El escalado de potencia con la distancia se rige por la pérdida de propagación en espacio libre, $FSPL(dB) = 20\cdot\log_{10}(d) + 20\cdot\log_{10}(f) + 20\cdot\log_{10}(4\pi/c)$. Se incluye aquí únicamente como justificación de por qué el control del perímetro cercano es un requisito de seguridad, no como parámetro de diseño de ningún emisor. Este documento modela propiedades de riesgo del sistema defendido; no describe la construcción, el emplazamiento ni la operación de dispositivos de interferencia.

Fundamento de validez y metodología de evaluación

La validez de esta clase de vulnerabilidad no descansa en una demostración aislada, sino en cuatro fundamentos independientes que convergen. Enunciarlos explícitamente es lo que da rigor al análisis y lo que permite evaluarlo sin reproducir ningún ataque sobre sistemas reales.

1. Fundamento estructural. Que la adquisición sobre el preámbulo precede y es independiente de la validación del STS es un hecho de diseño del propio estándar IEEE 802.15.4z, no una conjetura. La secuencia de campos y el orden de procesamiento en el receptor lo determinan.
2. Fundamento físico. La degradación del pico de correlación normalizada ante energía en banda no correlada es una consecuencia directa de la teoría de detección y del procesado de señal; se deduce analíticamente de la definición del NCC de la sección anterior.
3. Fundamento empírico. La viabilidad práctica ha sido demostrada y replicada de forma independiente en la literatura revisada por pares (UWBAD y trabajos afines), sobre hardware comercial y en condiciones controladas. La evaluación de riesgo puede apoyarse en esos resultados publicados sin necesidad de reproducirlos.
4. Fundamento analítico. El impacto posicional y la carga combinatoria del TDOA son cuantificables mediante modelado y simulación numérica, que no requieren emisión radioeléctrica alguna.

Cómo validar las contramedidas de forma ética y conforme a normativa. El objeto de una evaluación defensiva no es demostrar el ataque, sino medir cuánto lo neutraliza cada mitigación. La metodología recomendada es escalonada:

- Simulación primero. Modelar la cadena de adquisición PHY, inyectar una fuente de interferencia modelada en la ventana del preámbulo y medir la tasa de éxito de

sincronización con y sin cada contramedida. Es reproducible, no radia y permite barrer parámetros imposibles de cubrir en laboratorio.

- Validación física confinada, solo si es imprescindible. Cualquier ensayo con hardware debe realizarse en radiofrecuencia conducida (señal guiada por cable y atenuadores) dentro de recintos apantallados certificados (jaula de Faraday o cámara anecoica), sin radiación al exterior. Emitir UWB por encima de los límites del CNAF fuera de un recinto confinado constituye una infracción administrativa o penal. El objetivo del banco es someter al sistema defendido a una fuente de interferencia de referencia controlada para medir su resiliencia, no construir ni perfeccionar un emisor desplegable.
- Autorización y divulgación responsable. Ningún ensayo debe ejecutarse sobre infraestructura en producción de terceros sin autorización expresa, por escrito y legalmente vinculante del propietario. Los hallazgos sobre productos comerciales deben canalizarse por divulgación responsable hacia el fabricante antes de cualquier publicación.

Métricas defensivas. Los indicadores que sostienen conclusiones sólidas son la tasa de recepción de paquetes (PRR) y de error (PER), la tasa de éxito de sincronización, la estacionariedad estadística del perfil de canal (CIR), la latencia y la carga del solver TDOA, y el error de localización de fuentes estáticas. Conviene tratar cualquier cifra categórica de impacto —por ejemplo, pérdidas de paquete cercanas al 100 % bajo interferencia dirigida— como una hipótesis a contrastar en simulación y banco confinado, y a reportar con sus condiciones y márgenes, no como un dato absoluto.

Estrategias de mitigación y robustez

La defensa eficaz es en profundidad: ninguna capa basta por sí sola, pero tres contramedidas concurrentes —una en PHY, una en el procesado de señal y una en el servidor— cubren el vector de forma complementaria. La tabla las resume y los apartados siguientes las desarrollan.

Contramedida	**Capa**	**Principio**	**Qué neutraliza**
Aleatorización temporal (jitter con PRNG)	MAC / PHY	Romper la predictibilidad del instante de emisión	La sincronización del ataque reactivo
Discriminación por firma del CIR	Procesado (DSP) del receptor	Separar fuentes estáticas del tag móvil por estacionariedad del canal	La inyección desde emisores fijos

Contramedida	Capa	Principio	Qué neutraliza
Localización inversa TDOA	Servidor central	Geolocalizar fuentes anómalas persistentes con la propia infraestructura	La permanencia del ataque; habilita su retirada

1. Aleatorización temporal de la transmisión. La eficacia del ataque reactivo depende de que el adversario pueda anticipar la apertura de la ventana del SYNC. Si el intervalo entre tramas es constante, esa ventana es predecible. La contramedida consiste en introducir un retardo pseudoaleatorio (jitter) trama a trama, generado por un PRNG criptográficamente seguro (por ejemplo, un flujo derivado de AES en modo contador o de SHA-256 truncada) a partir de una semilla compartida entre el tag y el servidor durante el handshake de asociación. El adversario, que desconoce la semilla, no puede predecir el instante de emisión; si la dispersión del jitter supera la incertidumbre temporal del atacante, su pulso reactivo llega a destiempo y el preámbulo legítimo se adquiere limpio. El diseño debe equilibrar la magnitud del jitter con la tasa de actualización y las restricciones de planificación TDMA, y conviene caracterizar la eficacia residual como función de la distribución del jitter.

2. Filtrado dinámico por firma estadística del CIR. Una fuente de interferencia anclada a un elemento fijo genera una respuesta al impulso del canal (CIR) invariante en el tiempo: su perfil de retardos y multitrayecto no cambia. El tag legítimo, en movimiento, produce un CIR que varía de forma continua. La etapa DSP del receptor puede calcular el CIR de cada recepción, extraer características (posición del primer camino, dispersión de retardos, perfil de energía) y aplicar un contraste de estacionariedad sobre una ventana deslizante: las firmas persistentemente invariantes se marcan como no correspondientes al tag y se penalizan o descartan. Esta discriminación opera donde el filtrado por ángulo de llegada falla, ya que no depende de la separación angular sino de la dinámica temporal del canal. Requiere control de falsos positivos para tags legítimamente inmóviles.

3. Localización inversa TDOA de emisores estáticos. La última línea de defensa convierte la propia infraestructura sincronizada en un sistema de caza de emisores. Un hilo paralelo en el servidor central invierte el problema de posicionamiento: trata los arribos anómalos como emisores y resuelve las hipérbolas TDOA para estimar sus coordenadas. Como las fuentes hostiles estáticas repiten la misma geometría época tras época, la estimación converge rápidamente y con bajo error; el resultado se proyecta sobre el plano del recinto y se entrega al personal de seguridad para su verificación y, en su caso, retirada física durante las pausas reglamentarias. La inmovilidad que hace potente al ataque es, precisamente, lo que lo hace localizable.

Defensa en profundidad. Estas tres capas se refuerzan entre sí y deben acompañarse de medidas transversales: monitorización de espectro sensible a características transitorias (no solo a energía promediada, que el ataque reactivo evade), redundancia y diversidad de anclas, acotación explícita del espacio de asociación en el solver TDOA para evitar su saturación, y degradación elegante del servicio de posicionamiento bajo carga en lugar de colapso. La combinación —imprevisibilidad temporal, discriminación por canal y geolocalización de la amenaza— eleva de forma sustancial el coste y la detectabilidad de cualquier intento de denegación de servicio.

Conclusiones

La enmienda IEEE 802.15.4z resuelve con solvencia el problema para el que fue diseñada —la integridad de la medida de distancia—, pero no cubre la disponibilidad de la fase de adquisición. El STS protege el qué se mide, no el que se llegue a medir. Por ello, una interferencia reactiva dirigida al preámbulo público puede negar el servicio de un RTLS sin quebrar ninguna clave, y este riesgo es estructural: nace del orden de procesamiento en el receptor, no de un defecto de implementación concreto.

Para un RTLS de misión crítica, la implicación de gestión es directa. La robustez no puede delegarse únicamente en las primitivas criptográficas de capa superior; exige defensas adaptativas en la capa física y una estrategia de seguridad que integre lo lógico, lo radioeléctrico y lo físico-perimetral. Las tres contramedidas desarrolladas —aleatorización temporal con PRNG, discriminación por firma del CIR y localización inversa TDOA— atacan el problema desde capas distintas y se refuerzan mutuamente: la primera destruye la predictibilidad que el ataque necesita, la segunda distingue lo estático de lo móvil donde la geometría no basta, y la tercera transforma la persistencia de la amenaza en la señal que permite localizarla y retirarla.

El mensaje final para el responsable de seguridad es que la alta disponibilidad en entornos RTLS críticos es un requisito de diseño de sistema, no una propiedad heredada del estándar. Anticipar el fallo, modelar el riesgo en términos de propiedades del sistema y validar las contramedidas en entornos confinados y conformes a la normativa es la vía para convertir una vulnerabilidad estructural en un riesgo gestionado.

Referencias

Referencias verificadas contra las fuentes originales, en formato de indexación IEEE.

1. IEEE Computer Society, “IEEE Standard for Low-Rate Wireless Networks — Amendment 1: Enhanced Ultra-Wideband (UWB) Physical Layers (PHYs) and Associated Ranging Techniques,” IEEE Std 802.15.4z-2020, 2020.
2. Y. Yang, Z. Wu, Y. Zhang, T. Chen, J. Li, J. Yang, W. Liu, X. Zhang, R. Shi, J. Li, Y. Jiang y Z. Su, “UWBAD: Towards Effective and Imperceptible Jamming Attacks Against

UWB Ranging Systems with COTS Chips," en Proc. 2024 ACM SIGSAC Conf. on Computer and Communications Security (CCS '24), Salt Lake City, UT, 2024. DOI: 10.1145/3658644.3670349.

3. P. Leu, G. Camurati, A. Heinrich, M. Roeschlin, C. Anliker, M. Hollick, S. Capkun y J. Classen, "Ghost Peak: Practical Distance Reduction Attacks Against HRP UWB Ranging," en Proc. 31st USENIX Security Symposium, 2022, pp. 1343–1359.
4. C. Anliker, G. Camurati y S. Capkun, "Time for Change: How Clocks Break UWB Secure Ranging," en Proc. 32nd USENIX Security Symposium, 2023. arXiv:2305.09433.
5. M. Singh, M. Roeschlin, E. Zalzala, P. Leu y S. Čapkun, "Security Analysis of IEEE 802.15.4z/HRP UWB Time-of-Flight Distance Measurement," en Proc. 14th ACM Conf. on Security and Privacy in Wireless and Mobile Networks (WiSec), 2021, pp. 227–237.
6. K. Joo, D. H. Lee, Y. Jeong y W. Choi, "Protecting HRP UWB Ranging System Against Distance Reduction Attacks," en Proc. 2023 ACM SIGSAC Conf. on Computer and Communications Security (CCS '23), pp. 622–635.
7. Ministerio para la Transformación Digital y de la Función Pública, "Cuadro Nacional de Atribución de Frecuencias (CNAF)," regulación de dispositivos de corto alcance (SRD) en banda ultraancha (límite de −41,3 dBm/MHz), España.

Nota de verificación: *la contramedida de retardos pseudoaleatorios desarrollada en este documento coincide con la recomendación de los propios autores de UWBAD (sección de countermeasures del artículo [2]), que proponen un retardo aleatorio de magnitud no inferior a la duración del paquete para impedir el solapamiento del pulso reactivo.*